Auditoría de migramoxx.github.io

05/10/2026, con una medición agregada el 13/10/2026 · Milagros Canestro

> **Es mi propio sitio.** Lo audité como audito el de un cliente, con el mismo método y la misma forma de informe. Sirve de muestra: así es lo que recibís.

En una frase

Tu sitio es seguro para lo que hace: no guarda cookies, no publica ninguna clave y lo que dice tu política de privacidad coincide con lo que el sitio hace de verdad. Encontré dos cosas para arreglar en el código, que se arreglaron el mismo día y subieron la nota de **C− a B**. Lo que falta para la A no depende del código sino del hosting, y te digo cuál.

Las notas

EXAMEN	ANTES (05/10)	DESPUÉS (05/10, 22:11 UTC)	QUÉ MIDE
Mozilla Observatory	**C− (45)**	**B (70)**	Las protecciones que el sitio le pide al navegador
Qualys SSL Labs	B	B	Qué tan bien cifrada viaja la información
internet.nl	76 %	76 % + `security.txt`	Estándares modernos (IPv6, DNSSEC, HTTPS)

La B es el techo de este hosting. GitHub Pages no deja configurar dos protecciones (X-Frame-Options y X-Content-Type-Options) ni el cifrado de sus servidores, que es lo que baja SSL Labs y parte de internet.nl. No es un error del sitio: es de GitHub, y ningún programador lo puede arreglar ahí.

Si se muda a Cloudflare Pages (gratis), con la plantilla de cabeceras que uso para los sitios de clientes, la simulación da **A+ (115)**. *Medido el 13/10/2026 en una simulación local de Cloudflare Pages con el mismo sitio compilado y el examen oficial de Mozilla (código abierto, versión 1.7.1). Para comprobar que la simulación es confiable, simulé también el hosting actual: dio 75 contra la B (70) real, y los 5 puntos de diferencia son una cabecera que Cloudflare agrega sola. La nota en un sitio publicado se confirma el día de la mudanza.*

Lo que tu política dice y lo que tu sitio hace

LA POLÍTICA DICE	LO MEDIDO	¿COINCIDE?
No usa cookies	0 cookies (Webbkoll)	✅
Usa Umami, una analítica sin cookies	Umami es el único tercero: `cloud.umami.is` y `gateway.umami.is`	✅
Guarda el tema y el idioma en el navegador	`localStorage`, solo esas dos cosas	✅ (Webbkoll no lo ve hasta que se cambia; se leyó el código)
El chat guarda una sesión mientras está abierto	`sessionStorage`, una clave del chat	✅ (Webbkoll no abre el chat; se leyó el código)
No se toman decisiones automáticas sobre las personas	El puntaje del CRM solo ordena a quién responder primero	✅

> Esto compara la política con el comportamiento del sitio. No es asesoramiento legal: si hubiera que reescribir la política, conviene que la revise un abogado.

Hallazgos, del más importante al menos

1. Alguien podría hacer correr código ajeno en la página · arreglado

- **Qué podía pasar:** el sitio no tenía una regla que le dijera al navegador qué código puede ejecutar. Si alguna vez entrara un texto malicioso (por un formulario o un servicio de terceros), el navegador lo ejecutaría.
- **Qué tan probable:** baja (es un sitio estático, sin formularios propios), pero es la protección que más pesa en el examen: −25 puntos.
- **Quién lo arregla y cuánto lleva:** el programador, una tarde. Se hizo el mismo día.
- **Detalle técnico:** CSP por `<meta>` con los *hashes* de cada guion en línea calculados después del build (`csp-hashes.mjs`), sin `'unsafe-inline'` en `script-src`. Más Referrer-Policy por `<meta>`.
- **Cómo sabemos que quedó arreglado:** un guion inyectado desde la consola del navegador queda bloqueado («violates the following Content Security Policy directive»), en todas las páginas, y la analítica sigue mandando (200).

2. Componentes del sitio con fallas conocidas · arreglado

- **Qué podía pasar:** la versión de Next.js tenía 1 falla crítica y 2 altas. **No afectaban al sitio publicado**, que es HTML estático sin servidor, pero sí a la computadora de quien lo programa cuando lo prueba en una red compartida.
- **Quién lo arregla y cuánto lleva:** el programador, minutos (una versión de mantenimiento, sin cambios grandes).
- **Detalle técnico:** Next 16.2.2 → 16.3.8; `npm audit`: 0.

- **Cómo sabemos que quedó arreglado:** `npm audit` en 0 y el sitio compila igual.

3. Faltaba el contacto de seguridad · arreglado

- **Qué podía pasar:** si alguien encuentra un problema, no tiene dónde avisar.
- **Detalle técnico:** `/.well-known/security.txt` con el mail que el sitio ya publicaba; vence el 04/10/2027.
- **Cómo sabemos que quedó arreglado:** la medición lo encuentra y muestra la fecha de vencimiento.

4. Lo que falta para la A · depende del hosting

- **Qué pasa:** X-Frame-Options (−20) y X-Content-Type-Options (−5) son cabeceras que GitHub Pages no deja poner.
- **Quién lo arregla:** el hosting. En Cloudflare Pages (gratis) se ponen con un archivo; la simulación da A+.
- **Cómo sabemos que quedó arreglado:** el examen de Mozilla sobre el sitio publicado en el hosting nuevo.

Lo que está bien

- Ninguna clave publicada (de IA, de Google, de GitHub, llaves privadas), ni en el sitio ni en sus archivos.
- Ningún archivo que no debería estar (`.env`, mapas del código fuente).
- HTTPS obligatorio, con renovación automática del certificado.
- El chat solo acepta conversaciones desde este sitio: probado con orígenes trucados, todos rechazados.
- Los enlaces que abren otra pestaña están protegidos.

Lo que no se revisó

- No se hicieron pruebas activas (escáneres que atacan): no estaban en el alcance.
- El servidor del chat se audita aparte (es la auditoría del bot).
- Un descuento de 5 puntos que se acepta a propósito: la analítica se carga sin «integridad» fija, porque el proveedor actualiza su guion y un valor fijo la dejaría de contar sin avisar.

Qué no es este informe

No es una certificación ni un dictamen legal. Dice qué se midió en esas fechas, con herramientas públicas y sin atacar el sitio, y cómo se arregla lo que apareció.

Nueva prueba y constancia

Lo arreglado se volvió a medir el mismo día (B, 70). Con la mudanza a Cloudflare se mide otra vez sobre el sitio publicado. Con cada auditoría va una constancia firmada de qué se revisó, cuándo y con qué método.